

Incident Response Engagement Findings & Detection Report

INC-2026-004 - SQL Injection & Credential Reuse

CLIENT

NexaCorp Industries

SQL injection investigation, employee self-service portal

Engagement reference INC-2026-004

Target host bru-web-01

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 11 June 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
METHODOLOGY	6
INCIDENT TIMELINE	8
TECHNICAL ANALYSIS	9
4.1 SQL injection on the id parameter	9
4.2 Database enumeration and users dump	10
4.3 Weak credential recovered offline	11
4.4 Credential reuse, SSH foothold	12
RISK MATRIX	13
MITRE ATT&CK MAPPING	14
DETECTION ENGINEERING	15
REMEDATION	16
TOOLS AND STANDARDS	17
GLOSSARY AND ACRONYMS	19

Confidentiality Statement

This report documents INC-2026-004 of the BeCode Corp internal cybersecurity training programme, an incident response engagement against a controlled laboratory environment simulating a SQL injection incident on the fictitious organisation NexaCorp's employee portal. No real production system, customer data, or third party was involved. All identities, hostnames and accounts referenced belong to the BeCode training environment.

This document is classified Confidential, do not distribute outside BeCode Corp, under reference BCC-2026 | INC-2026-004. Raw evidence is retained by BeCode Corp and is not redistributed. Publication for portfolio use was authorized by the BeCode lab coach (Thomas B.) on 2026-05-17.

Disclaimer

The findings are based on the evidence bundle provided for INC-2026-004 (web access log, network capture, Wazuh alert export, auth log) covering 2026-05-30. The methodology follows NIST SP 800-61r2 and the SANS PICERL process. The root vulnerability is classified under OWASP A03:2021 Injection.

Executive Summary

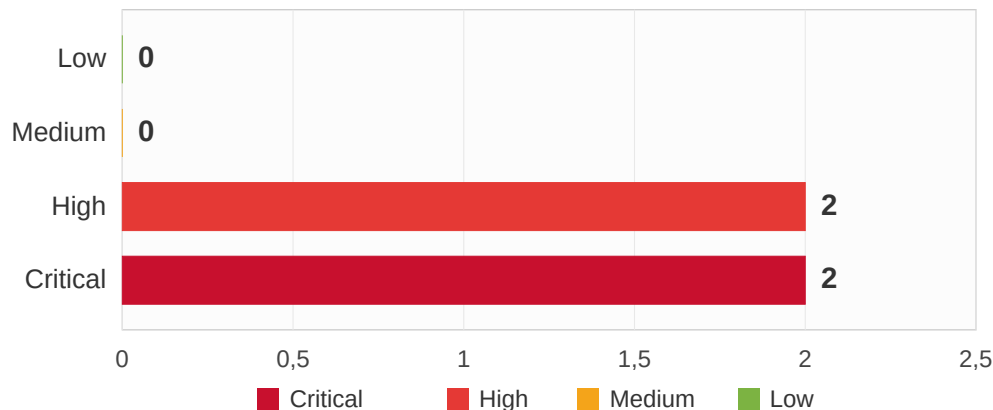
A. Plain-language summary

Someone outside the company found a weak spot in the staff portal and used it to read the company database through the web page itself. They pulled out the list of user accounts and their scrambled passwords. One staff account, j.martin, had a password weak enough to be unscrambled in seconds on an ordinary laptop. A few hours later, that same outsider used the recovered password to log in to the server directly, and it worked. Every password stored in the portal should be considered exposed.

B. Engagement summary

An external attacker (172.16.50.10) exploited a SQL Injection vulnerability in the id parameter of the NexaCorp employee portal (bru-web-01). The attacker confirmed the flaw with an error-based probe, mapped the database, and exfiltrated the full users table : six accounts and their MD5 password hashes. The employee account j.martin used a weak password recovered offline in under one second. About five hours later, the attacker reused that credential to authenticate over SSH and succeeded, then attempted to spray the other stolen accounts (which failed). The outcome is a confirmed authenticated foothold on bru-web-01 and the exposure of every credential in the portal database.

Findings by Severity Level



B.

C. Overview of findings

Ref	Description	Severity
4.1	SQL Injection on the id parameter of the employee portal	CRITICAL
4.2	Database enumeration and full users-table exfiltration (6 accounts)	HIGH
4.3	Weak credential (j.martin) recovered offline from MD5	HIGH
4.4	Credential reuse: successful SSH foothold as j.martin	CRITICAL

D. Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
4.1	SQL injection	Parameterized queries (prepared statements) on id; server-side input validation.
4.2	Users-table dump	Treat every dumped account as compromised; force resets; fix the injection.
4.3	Weak credential	Block breached/common passwords; enforce MFA; migrate MD5 to bcrypt/argon2.
4.4	SSH reuse	Disable/reset j.martin now; block 172.16.50.10; MFA + lockout on SSH; restrict SSH to VPN.

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 and the SANS PICERL process, mapping every finding to MITRE ATT&CK Enterprise v15. It is an investigation lab with a detection-engineering phase (Suricata rules validated by offline replay).

01. Web access log analysis

- Identify the attacker IP and the abused parameter
- Reconstruct the SQLi technique chain from the URIs



02. PCAP response analysis

- Follow HTTP streams to recover server responses
- Confirm the database name and the dumped users table



03. SIEM and consequence analysis

- Review Wazuh alerts and auth.log
- Confirm the offline crack and the SSH credential reuse



04. Detection engineering

- Author Suricata rules for each SQLi technique
- Validate by offline replay of the capture



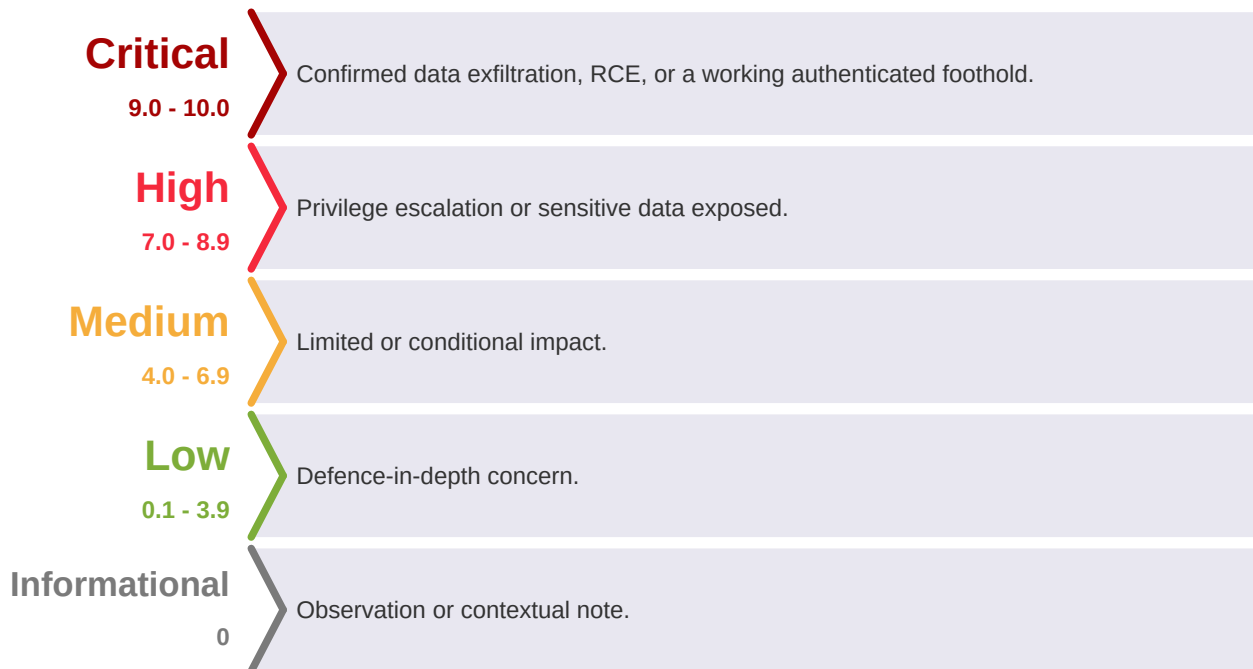
05. Consolidation and reporting

- Map findings to MITRE ATT&CK;
- Consolidate IOCs and remediation



B. Severity ratings

Severity uses CVSS v3.1 as foundation with engagement-contextual elevation where confirmed exfiltration or a working foothold materially exceeds the base.



Incident Timeline

Timestamps in web server local time (UTC+02:00), matching web_access.log (the authoritative request record).

<i>Time (+02:00)</i>	<i>Event</i>	<i>Source</i>
09:35:02	Error-based probe (single quote id=1')	web_access.log
09:37:24 - 09:37:27	Column counting (ORDER BY 1/2 -> 200, ORDER BY 3 -> 500): 2 columns	web_access.log
09:37:28 onward	UNION exploitation (@@version, database(), information_schema)	web_access.log
09:38:29	Database name read: dvwa	pcap (stream 14)
09:39:58	Full users table exfiltrated (6 accounts + MD5 hashes) - exfiltration anchor	pcap (stream 447)
09:41:38	Blind boolean probing (SUBSTRING)	web_access.log
14:48:06	Successful SSH login as j.martin from 172.16.50.10, then failed spray of other accounts	auth.log

Technical Analysis

4.1 SQL Injection on the id parameter

Severity:**CRITICAL**

Finding type:Injection (SQL) on a public-facing parameter

CVSS v3.1 base score:9.8 (Critical) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE:CWE-89 (SQL Injection)

MITRE ATT&CK:T1190 (Exploit Public-Facing Application)

Affected scope:

- bru-web-01, endpoint /dvwa/vulnerabilities/sqli/, parameter id
-

Description:

The id parameter passes user input directly into a back-end SQL query without separating data from instructions. The attacker confirmed the flaw with an error-based probe (id=1', 1", 1' OR '1'='1), counted columns with ORDER BY (3 returns HTTP 500, so the query returns 2 columns), then used UNION SELECT to read @@version, database() and information_schema.

Impact:

Full read access to the back-end database through the public-facing portal.

4.2 Database enumeration and full users-table exfiltration

Severity:**HIGH**

Finding type:Data exfiltration from a database

CVSS v3.1 base score:7.5 (High) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CWE:CWE-200 (Exposure of Sensitive Information)

MITRE ATT&CK:T1213 (Data from Information Repositories)

Affected scope:

- dvwa database on bru-web-01
-

Description:

Using the confirmed UNION injection, the attacker read the database name (dvwa) and dumped the complete users table, exposing six accounts and their MD5 password hashes (admin, gordonb, 1337, pablo, smithy, and the employee account j.martin). The dumping response (stream 447) was the largest of the session. Exfiltration anchor : 2026-05-30 09:39:58 (+02:00).

Impact:

Every credential stored in the portal database is exposed. The account of operational concern is j.martin, the only real-employee pattern and the only one the attacker re-queried by name.

Evidence:

```
# users dump recovered from the PCAP (Follow HTTP Stream 447), hashes redacted
admin:[REDACTED-md5]
gordonb:[REDACTED-md5]
j.martin:[REDACTED-md5]    <- NexaCorp employee account
```

4.3 Weak credential recovered offline

Severity:

HIGH

Finding type:

Weak credential / offline password cracking

CVSS v3.1 base score:

N/A (offline, against exfiltrated hash)

CWE:

CWE-916 (Use of Password Hash With Insufficient Computational Effort), CWE-521

MITRE ATT&CK:

T1110.002 (Brute Force: Password Cracking)

Affected scope:

- account j.martin
-

Description:

The MD5 hash of j.martin was recovered offline against the standard rockyou.txt wordlist using John the Ripper, on the analyst workstation, never against the live server. The recovery took under one second. The cleartext satisfies a typical complexity policy (upper/lower/digit/special, 11 characters) yet falls instantly because the pattern is common and present in standard wordlists : syntactic complexity is not resistance to guessing.

Impact:

A usable cleartext credential for a real employee account, enabling the credential-reuse foothold (4.4).

4.4 Credential reuse, successful SSH foothold

Severity:**CRITICAL**

Finding type:Valid-account access via reused credential

CVSS v3.1 base score:8.8 (Critical) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE:CWE-522 (Insufficiently Protected Credentials), CWE-308

MITRE ATT&CK:T1078 (Valid Accounts), T1021.004 (SSH)

Affected scope:

- bru-web-01 (SSH service)
-

Description:

The stolen and cracked credential was reused against SSH on the same server. The login succeeded at 14:48:06 from 172.16.50.10 (the SQLi source), giving the attacker an authenticated foothold under a legitimate employee identity. The attacker then sprayed other dumped accounts (all failed). The ~5h gap between the dump (09:39:58) and the login (14:48:06) is consistent with offline cracking before reuse.

Impact:

A confirmed interactive foothold on the server under a real employee identity : the entry point for follow-on activity (this account is reused in INC-2026-005).

Evidence:

```
2026-05-30T14:48:06 bru-web-01 sshd[14736]: Accepted password for j.martin from 172.16.50.10
port 49145 ssh2
session opened for user j.martin(uid=1001)
```

Risk Matrix

Each finding plotted by Impact against Likelihood. Upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				4.4	4.1
High (4)			4.3	4.2	
Medium (3)					
Low (2)					
Very Low (1)					

Critical	High	Medium	Low
----------	------	--------	-----

4.1 (SQL injection) and 4.4 (working SSH foothold) are Critical ; 4.2 (full credential dump) and 4.3 (weak credential) are High. The chain ends in a confirmed foothold, so remediation is urgent.

MITRE ATT&CK Mapping

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
4.1	Initial Access	T1190	Exploit Public-Facing Application
4.2	Collection	T1213	Data from Information Repositories
4.3	Credential Access	T1110.002	Brute Force: Password Cracking
4.4	Initial Access / Persistence	T1078	Valid Accounts
4.4	Lateral Movement	T1021.004	Remote Services: SSH

Framework : MITRE ATT&CK Enterprise v15. Root vulnerability : OWASP A03:2021 Injection.

Detection Engineering

After the investigation reconstructed the attack, four Suricata signatures were written to detect each SQL injection technique observed, then validated by replaying the capture offline (suricata -r attack.pcap). The host had no default ruleset, so the baseline was zero alerts and every count below comes from these four local rules. Each rule inspects the normalized http.uri buffer, so URL-encoded payloads are matched in decoded form.

<i>SID</i>	<i>Detection</i>	<i>Technique</i>	<i>MITRE</i>	<i>Alerts</i>
1000001	UNION SELECT in URI	UNION-based extraction	T1190	16
1000002	Single quote probe	Error-based probing	T1190	44
1000003	Blind boolean (SUBSTRING)	Boolean blind injection	T1190	18
1000004	information_schema enum	Schema enumeration	T1213	2

The single-quote probe fires most often because the apostrophe is the common opening token across nearly every injection variant. These rules are lab-tuned ; production deployment would need tighter scoping (source/destination, flow:established) and narrower content matches on generic keywords. The full ruleset and false-positive notes are in the detection/ folder.

Remediation

P0 - immediate (within hours)

- Disable or reset j.martin and terminate active sessions (the attacker holds valid SSH access).
- Block 172.16.50.10 at the perimeter.
- Force a password reset for every account in the dumped users table.

P1 - short term (within days)

- Fix the root cause : parameterized queries on the id parameter, plus input validation.
- Harden SSH : MFA, restrict to internal or VPN, lockout against spraying.
- Enforce a password policy that blocks common and breached passwords.

P2 - medium term

- Migrate password storage from unsalted MD5 to bcrypt or argon2.
- Deploy the Suricata SQLi signatures (detection/ folder) on the segment ingress.
- Review segmentation : external SSH to bru-web-01 should not be reachable.

Tools and Standards

A. Tools used during the engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Log analysis	grep / awk	Identify the attacker IP, parameter and SQLi technique chain in web_access.log
Network capture analysis	tshark / Wireshark	Follow HTTP streams to recover the database name and the users dump
Password cracking	John the Ripper + rockyou.txt	Offline recovery of the j.martin MD5 hash (analyst workstation)
Detection engineering	Suricata	Author and validate the four SQLi signatures by offline replay
Documentation	VS Code, Markdown	Note-taking and report drafting

B. Standards and frameworks followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping
OWASP Top 10	2021	A03:2021 Injection (root vulnerability)
CVSS	v3.1	Severity scoring
CWE	v4.16	Root-cause classification (CWE-89, 200, 916, 522)
Suricata rule syntax	-	Detection rule authoring (SID 1000001-1000004)

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
SQLi	SQL Injection	Injecting SQL through user input that is not separated from the query
UNION SELECT	SQL UNION	Appends a second query to read data from other tables
DVWA	Damn Vulnerable Web Application	Deliberately vulnerable training web app
MD5	Message Digest 5	Fast unsalted hash, unsuitable for passwords
rockyou.txt	rockyou wordlist	Standard password wordlist used for offline cracking
SSH	Secure Shell	Encrypted remote-administration protocol
MFA	Multi-Factor Authentication	Additional authentication factor beyond a password
IOC	Indicator of Compromise	Artifact pointing to malicious activity
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
OWASP	Open Worldwide Application Security Project	A03:2021 Injection covers SQLi
CWE	Common Weakness Enumeration	Classification of software weaknesses
PCAP	Packet Capture	Captured network traffic

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-004

Classification: Confidential, do not distribute outside BeCode Corp

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi